

## CIA Triad (Confidentiality • Integrity • Availability)

The CIA triad is the **core model of information security**. Every security control, policy, and SOC alert ultimately protects one or more of these three goals:

- **Confidentiality** – Only the right people/systems can access the data.
- **Integrity** – Data is accurate, complete, and unaltered (unless authorized).
- **Availability** – Systems and data are up and usable when needed.

Think of it as a **three-legged stool**: if any one leg fails, security fails.

### 1) Confidentiality

#### What it means:

Preventing **unauthorized disclosure** of information (planned secrecy).

#### Why it matters (impact if broken):

- Privacy violations, IP theft, legal penalties (e.g., data protection laws), brand damage.

#### Typical threats/causes:

- Phishing → credential theft
- Misconfigured cloud storage (e.g., public S3 bucket)
- Shoulder surfing/insider snooping
- SQL injection exposing records
- Insecure APIs, weak encryption, shared passwords

#### Common controls (prevention):

- **Access control**: Least privilege, role-based access (RBAC), just-in-time access
- **Strong authentication**: MFA, FIDO2, SSO
- **Encryption**: At rest (disk/DB), in transit (TLS), end-to-end where applicable
- **Data classification & DLP**: Label data (Public/Internal/Confidential/Restricted) and monitor movements
- **Network segmentation**: Separate sensitive zones (Prod/PCI/HR)
- **Secrets management**: Vaults for keys, rotation, no secrets in code

#### SOC detection examples:

- Alert on **MFA disabled** for privileged users
- DLP alert on **bulk downloads** or exfiltration to personal email/cloud
- Spike in **failed logins** from unusual geos
- Unusual queries on PII tables in DB logs

#### Quick example:

A marketing intern downloads 50,000 customer records to a USB. DLP + EDR + access logs should catch/block this, and SOC responds.

### 2) Integrity

#### What it means:

Keeping data **correct, consistent, and unaltered** except by authorized actions.

#### Why it matters (impact if broken):

- Wrong decisions from wrong data (e.g., tampered financials)
- Fraud, safety issues (e.g., altered medical records), compliance failures

#### Typical threats/causes:

- Malware that **modifies files** (web shells, backdoors)
- Man-in-the-middle altering traffic
- Insider changes to logs (“log tampering”)
- Application bugs leading to corruption
- Supply-chain attacks (tampered packages or images)

#### Common controls (prevention/assurance):

- **Hashing & signatures:** Checksums (SHA-256), code signing, artifact attestation
- **Immutable logging:** WORM storage, centralized SIEM, write-once cloud buckets
- **Database safeguards:** Constraints, transactions, audit trails
- **Version control:** Git with signed commits, protected branches
- **Configuration management:** IaC + drift detection (e.g., Terraform + policy as code)
- **Input validation:** Prevent injection and data corruption

#### SOC detection examples:

- Alert on **unexpected file changes** to critical binaries (FIM – File Integrity Monitoring)
- **Unsigned** or **recently re-signed** binaries executing in prod
- **Log gaps** or tamper patterns (hash mismatch, sequence breaks)
- **Package pulls** from unapproved registries

#### Quick example:

A web server file gets silently replaced with a backdoored version. FIM detects checksum change → SOC isolates host, restores from trusted image, investigates root cause.

### 3) Availability

#### What it means:

Systems and data are **accessible** within required **timeframes** (SLAs).

#### Why it matters (impact if broken):

- Downtime → lost revenue, disrupted operations, missed SLAs, safety issues.

#### Typical threats/causes:

- DDoS, ransomware, destructive malware (wipers)
- Hardware failure, power outage, misconfigurations
- Capacity exhaustion (traffic spikes), dependency outages (DNS, cloud region)

#### Common controls (resilience):

- **Redundancy & HA:** Multi-AZ/region, clustering, load balancing
- **Backups & recovery:** 3-2-1 backups, offline/immutable copies, tested restores
- **Patch & hardening:** Reduce exploitable crashes/outages
- **Auto-scaling & rate limiting:** Absorb bursts, throttle abuse
- **Monitoring & SLOs:** Health checks, synthetic probes, error budgets
- **Runbooks & DR plans:** RTO/RPO defined, drills conducted

#### SOC detection examples:

- Early signals of **ransomware** (mass encryption behavior, shadow copy deletion)
- **DDoS indicators** (sudden traffic floods, protocol anomalies)

- **Service health** deviations correlated with security events (e.g., auth failures spike → potential attack)

### Quick example:

Ransomware starts encrypting file shares. EDR flags mass file rewrite; SOAR isolates endpoints, blocks C2, triggers backup restoration runbook.

### Putting It Together (one event touches many)

#### Ransomware →

- **Confidentiality:** Possible data theft prior to encryption (double extortion)
- **Integrity:** Files altered/encrypted (integrity loss)
- **Availability:** Services down (primary goal of attacker)

**SOC response** should map actions to each pillar: block exfil (C), verify/restore clean data (I), recover service (A).

### Quick Memory Aids

- **C:** “Who can see it?” (Access + Encryption)
- **I:** “Can I trust it?” (Hashes + Immutability)
- **A:** “Can I use it now?” (HA + Backups)

### Metrics & Targets (good for interviews and operations)

- **Confidentiality**
  - % of sensitive datasets encrypted at rest/in transit
  - MFA coverage for privileged accounts
  - Mean time to detect (MTTD) data exfil attempts
- **Integrity**
  - FIM coverage on critical assets
  - % of build artifacts with **verified signatures/SBOM**
  - Log integrity (hash chain) verification frequency
- **Availability**
  - Uptime/SLA (e.g., 99.9%)
  - **RTO/RPO** achieved in DR tests
  - Mean time to recover (MTTR) for security-driven outages

### Common Trade-offs & Design Tips

- **Encryption (C)** can add latency → plan capacity so **A** isn’t hurt.
- **Tight change controls (I)** can slow deployments → use **automation & approvals**.
- **Aggressive rate limiting (A protection)** can block legit users → add **allow-lists** and adaptive policies.
- Always **balance** the triad based on business risk and data classification.

### Mapping to Controls & Frameworks (fast reference)

- **NIST SP 800-53 / ISO 27001** controls span all three.
  - **C:** AC-, IA-, SC-13/SC-28 (encryption), ISO A.9 (access control)
  - **I:** AU-, SI-7 (*software/firmware integrity*), CM- (config mgmt), ISO A.12.1.2 (change mgmt)

- **A:** CP-\* (contingency/DR), SC-5 (DoS protection), ISO A.17 (business continuity)  
(You don't need to memorize numbers—use them to show alignment in policy/docs.)

## **Classroom Scenarios (use these to practice)**

### **1. Public S3 bucket with customer PII**

- Violates: **Confidentiality**
- Fix: Close public access, apply bucket policies, encrypt, enable Access Analyzer & DLP alerts.

### **2. Developer pushes unsigned binary to prod**

- Violates: **Integrity**
- Fix: Enforce signed artifacts, protected branches, FIM on servers, admission controllers in K8s.

### **3. Single DB server crashes; no recent backups**

- Violates: **Availability** (and maybe **Integrity** if corruption)
- Fix: HA pair/cluster, automated backups with restore tests, defined RTO/RPO.

## **How the SOC Uses CIA in Daily Work**

- **Alert triage** → tag each incident with affected pillar(s).
- **Playbooks** → steps mapped to **C/I/A** outcomes (block exfil, verify integrity, restore service).
- **Post-incident reviews** → which pillar failed, which control was weak, what to harden.